

THRIVE AFRICA

CYBERSECURITY INTERNSHIP

WEEK 6

Incident Response & Security Operations

Incident Response Playbook | Metasploitable 2 | Group 8

Document Reference:	GRP8-WEEK6-IRP-2026
Classification:	Internal – Internship Use Only
Target System:	Metasploitable 2 (Simulated Corporate Environment)
Framework:	NIST SP 800-61 Rev. 2 – Computer Security Incident Handling Guide
Version:	1.0 – Initial Release
Date:	May 2026
Prepared by:	Group 8, Thrive Africa Cybersecurity Internship

CONFIDENTIAL – For Training & Assessment Purposes Only

SECTION 1: INTRODUCTION & PURPOSE

1. Introduction

This Incident Response Playbook (IRP) is the Week 6 deliverable for Group 8 of the Thrive Africa Cybersecurity Internship. It builds on the vulnerability assessment (Week 3), risk analysis (Week 4), and security governance framework (Week 5) conducted against the Metasploitable 2 target system.

An Incident Response Playbook is a practical, operational document. Its purpose is not theoretical — it exists to be used under pressure, in real time, when something goes wrong. Every procedure in this playbook has been designed with one question in mind: can a team member follow this under stress and get it right the first time?

1.1 Purpose

This playbook serves four purposes:

- Define what constitutes a security incident in the context of the assessed environment
- Provide a structured, step-by-step response procedure for each phase of incident handling
- Assign clear roles and responsibilities so there is no confusion about who does what during an incident
- Establish communication and escalation channels to ensure the right people are informed at the right time

1.2 Scope

This playbook applies to all systems, services, and personnel in the simulated organisation, with particular focus on the vulnerabilities identified during Weeks 3 and 4. The 13 CVE-referenced vulnerabilities across 24 open ports on Metasploitable 2 define the specific threat landscape this playbook is designed to address.

1.3 Alignment with NIST SP 800-61

This playbook follows the NIST Computer Security Incident Handling Guide (SP 800-61 Rev. 2) lifecycle, which defines four phases:

Phase	NIST Name	What It Means in Practice
1	Preparation	Putting tools, plans, roles, and training in place before an incident occurs
2	Detection & Analysis	Identifying that an incident has occurred, gathering evidence, and assessing its severity
3	Containment, Eradication & Recovery	Stopping the spread, removing the threat, and restoring systems to normal operation
4	Post-Incident Activity	Reviewing what happened, updating controls, and learning from the incident

1.4 Link to Previous Weeks

Every scenario and procedure in this playbook is grounded in the specific vulnerabilities found during the Week 3 and 4

assessments. The most critical threats — the vsftpd backdoor (CVE-2011-2523), Samba RCE (CVE-2007-2447), UnrealIRCd backdoor (CVE-2010-2075), Ingreslock root shell (port 1524), and Telnet plaintext credentials (CVE-2022-39028) — each have dedicated response procedures in Section 6.

SECTION 2: INCIDENT CLASSIFICATION SYSTEM

2. Incident Classification System

Before responding to an incident, it must be classified. Classification determines who is notified, how fast they must respond, what level of authority is required to make decisions, and whether external parties (regulators, customers, law enforcement) need to be informed. Getting the classification right in the first few minutes is critical.

2.1 Severity Level Definitions

Level	Severity	Description	Response Time	Authority Required
CRITICAL	CRITICAL	Active confirmed breach, backdoor triggered, ransomware, root-level compromise, data exfiltration in progress	Immediate – ISO notified within 15 minutes; all-hands response activated	ISO + Board notification required. External legal/regulatory notification within 72 hours if data breach confirmed.
HIGH	HIGH	Suspected breach, credential compromise, unauthorised access to sensitive systems, malware detected but not spreading	Within 1 hour of detection	ISO declares incident. System Administrator leads technical response. Board informed within 4 hours.
MEDIUM	MEDIUM	Policy violation, suspicious activity, vulnerable service probed but not exploited, single account compromise	Within 4 hours of detection	System Administrator leads response. ISO informed. No Board notification required unless escalated.
LOW	LOW	Near miss, informational alerts, minor policy deviations with no system impact, failed scan or brute force with no success	Within 24 hours via standard report	Standard incident report to System Administrator. ISO notified in weekly digest.

2.2 Incident Type Classification

In addition to severity level, every incident is assigned a type. The type determines which specific playbook procedure applies (see Section 6).

Incident Type	Description & Examples	Linked CVEs / Threats	Typical Severity
Backdoor / Remote Access Trojan	Attacker-installed or pre-existing backdoor providing unauthorised shell access. Examples: vsftpd backdoor, UnrealIRCd backdoor, Ingreslock root shell on port 1524	CVE-2011-2523, CVE-2010-2075, Port 1524 (N/A)	Critical
Remote Code	Attacker executes arbitrary	CVE-2007-2447,	Critical

Execution (RCE)	commands on a target server. Examples: Samba username map script, distccd RCE	CVE-2004-2687	
Credential Theft / Eavesdropping	Credentials captured in transit over plaintext protocols or harvested from compromised systems. Examples: Telnet sessions intercepted, MySQL credentials brute-forced	CVE-2022-39028, CVE-2008-0226	High
Unauthorised Remote Access	Access to systems or desktops without authentication. Examples: VNC accessed without password (VNC 3.3 no-auth mode)	CVE-2006-2369	High
Data Exfiltration	Unauthorised copying or transmission of organisational data. Examples: NFS share accessed by unknown host; MySQL database dumped remotely	CVE-2006-3005, CVE-2008-0226	High / Critical
Denial of Service (DoS)	Service made unavailable through resource exhaustion or crash. Examples: PostgreSQL DoS via malformed query	CVE-2009-0922	Medium
Privilege Escalation	Attacker gains higher privileges than initially obtained. Examples: Apache mod_proxy config exploitation to escalate from web user to admin	CVE-2009-1195	High
Cross-Site / CSRF Attack	Web-based attack forcing authenticated users to execute unintended commands. Examples: ProFTPD CSRF via malicious webpage	CVE-2008-4242	Medium
Phishing / Social Engineering	Deceptive communication designed to harvest credentials or install malware. Not tied to a specific CVE but could lead to exploitation of any vulnerability.	N/A (access vector)	Medium / High
Policy Violation	User violates acceptable use, password, or access control policies. Examples: Use of Telnet; shared accounts discovered; installing unauthorised IRC client.	AUP (POL-005)	Low / Medium

2.3 Classification Decision Guide

When an incident is reported, use the following questions to determine its severity level quickly:

Question	If YES	If NO
Is an attacker currently active on the system (live session, live connection)?	CRITICAL	Continue
Has data been confirmed as accessed, copied, or exfiltrated?	CRITICAL	Continue

Has a backdoor, malware, or rootkit been confirmed on the system?	CRITICAL	Continue
Has an account been compromised or credentials stolen?	HIGH	Continue
Is a critical service unavailable or degraded?	HIGH	Continue
Is suspicious activity detected but not yet confirmed as a breach?	MEDIUM	Continue
Is this a policy violation or failed attack attempt with no confirmed impact?	LOW	Reassess — may not be an incident

SECTION 3: INCIDENT RESPONSE ROLES & RESPONSIBILITIES

3. Incident Response Roles & Responsibilities

During an incident, roles and responsibilities must be crystal clear. Confusion about who is doing what costs time — and time is the most critical resource in incident response. This section defines exactly who does what, from the moment an incident is detected to the moment the post-incident review is complete.

Role	Activated For	Responsibilities During an Incident
Incident Commander (ISO)	All incidents	Declares the incident and sets the severity level - Has overall authority and is accountable for all response decisions - Authorises containment actions (isolating systems, disabling accounts) - Notifies the Board and external parties (regulators) where required - Chairs the post-incident review and signs off the final report - Has authority to engage external forensics or law enforcement
Technical Lead (System Administrator)	All incidents	First technical responder — leads all hands-on response activities - Isolates affected systems from the network on ISO instruction - Preserves forensic evidence: disk images, memory dumps, log captures - Executes eradication steps: removes malware, closes backdoors, patches vulnerabilities - Validates system integrity before approving recovery - Documents all technical actions taken with timestamps
Data Custodian	High / Critical	Owns the data impact assessment — determines what data was accessed or lost - Identifies which data assets were exposed or at risk during the incident - Verifies backup integrity and leads data restoration procedures - Provides the ISO with the data impact report within 4 hours of incident declaration
Communications Officer (Designated Senior Staff Member)	High / Critical	Manages all internal and external communications during the incident - Drafts and distributes staff updates — no incident information goes out without ISO approval - Manages any media enquiries (no comment until legal and ISO review) - Coordinates customer or partner notification if their data may be affected
All Employees (First Responders)	All incidents	Every employee is a first line of detection — your job is to notice and report

		• Report suspicious activity immediately — do not investigate or attempt to fix yourself • Preserve evidence: do not close windows, restart systems, or delete files • Follow instructions from the Incident Commander — do not discuss the incident publicly or on social media
--	--	--

SECTION 4: INCIDENT RESPONSE LIFECYCLE

4. Incident Response Lifecycle

The incident response lifecycle defines the six phases every incident goes through, from before it happens (preparation) to after it is resolved (post-incident review). Each phase has specific actions, owners, and time targets. The phases are sequential for major incidents, but in fast-moving situations containment may begin before full analysis is complete.

PHASE 1 | PREPARATION

Preparation is the only phase that happens before an incident. It is also the phase that determines how well every other phase goes. A team that has prepared thoroughly will detect incidents faster, contain them more effectively, and recover more completely. Preparation is an ongoing activity – not a one-time task.

Technical Preparation

- Deploy and configure a centralised log management system to collect events from all servers, firewalls, and services. Log sources must include: SSH (port 22), web server (port 80), database (port 3306/5432), and any monitoring services.
- Configure network intrusion detection to alert on: connections to port 1524 (Ingreslock), connections on port 6667 (IRC/UnrealIRCd), outbound connections on port 21 (vsftpd), any traffic on port 23 (Telnet should be disabled – any traffic is suspicious)
- Maintain a current and tested backup of all critical data. Backups must be stored offline or on an isolated network segment. Test restoration quarterly.
- Build and maintain a list of all running services and their expected behaviour (a 'known-good' baseline). Any deviation from this baseline is a detection trigger.
- Prepare forensic response tools in advance: network capture tools (tcpdump/Wireshark), memory acquisition tools, disk imaging utilities. These must be available on a dedicated response USB or isolated server.

Process Preparation

- Ensure all personnel have read and signed the Incident Reporting Policy (POL-004, Week 5)
- Conduct tabletop exercises at minimum quarterly – walk through at least one scenario from Section 6 of this playbook
- Maintain an up-to-date contact list for: ISO, System Administrator, Data Custodian, Legal counsel, relevant regulators, external forensics vendor
- Pre-establish the incident communication channel (e.g., dedicated Slack channel #security-incidents, secure group chat, or emergency phone tree)

PHASE 2 | DETECTION & IDENTIFICATION

Detection is how we know something is wrong. Identification is how we understand what is wrong, how bad it is, and what systems are affected. These two activities happen in rapid succession – often within the same few minutes. Speed matters: the faster an incident is detected and classified, the less damage it can do.

Detection Sources

- Automated alerts: IDS/IPS alerts, antivirus/EDR detections, SIEM rule triggers, failed login threshold alerts
- Log analysis: unusual outbound connections, root login events, large data transfers, service crashes (e.g., PostgreSQL DoS)
- User reports: employee notices unusual system behaviour, receives phishing email, finds unknown files, or observes a colleague's account being used unexpectedly
- Third-party notification: external security researcher, partner organisation, or regulatory body reports a potential compromise
- Scheduled scans: monthly vulnerability scans identifying newly exposed services or changed configurations

Identification Steps

- Step 1. Receive the initial alert or report. Record the exact time, source, and initial description. Do not discard or dismiss – treat everything as potentially real until proven otherwise.
- Step 2. Review relevant logs. For a suspected backdoor exploitation on port 1524: check /var/log/syslog, netstat -an output, and authentication logs (/var/log/auth.log) for root session initiation.
- Step 3. Determine the scope: How many systems are potentially affected? Is the attack isolated to one server, or has lateral movement occurred across the network?
- Step 4. Classify the incident using the Severity Level table (Section 2.1) and the Classification Decision Guide (Section 2.3). Assign an incident type from the table in Section 2.2.
- Step 5. Assign an Incident ID (format: INC-YYYYMMDD-NNN, e.g., INC-20260502-001) and open the Incident Log (see Section 5).
- Step 6. Notify the ISO immediately. For Critical or High incidents: phone call. For Medium: Slack/messaging. For Low: email incident report form.

Key Indicators of Compromise (IoCs) – Environment-Specific

Service / Vulnerability	Indicator of Compromise	Where to Look
vsftpd backdoor (port 21)	Unexpected root shell via FTP connection; connection to port 6200 (backdoor trigger)	/var/log/vsftpd.log netstat -an grep 6200
Samba RCE (ports 139/445)	Shell spawned from smbd process; unexpected root process with parent PID of smbd	/var/log/samba/log.* ps aux grep smbd netstat -tlnp
Ingreslock root shell (port 1524)	ANY inbound connection on port 1524; root shell process with unusual parent	netstat -an grep 1524 /var/log/auth.log (root login events)
UnrealIRCd backdoor (port 6667)	AB; prefix in IRC traffic; shell process with parent unrealircd	/var/log/ircd/* netstat -an grep 6667 process tree analysis
Telnet credential theft (port 23)	Telnet session logs; successful auth following scan activity; reused credentials appearing in SSH	/var/log/auth.log packet capture on port 23 SSH login analysis
VNC auth bypass (port 5900)	Desktop session with no preceding authentication; screenshot activity from unknown IP	VNC log files netstat -an grep 5900 system event logs

MySQL data dump (port 3306)	Large outbound data transfer; mysqldump process; remote connection to 3306 from external IP	/var/log/mysql/mysql.log netstat -an grep 3306 Outbound traffic analysis
-----------------------------	---	--

PHASE 3 | CONTAINMENT

Containment stops the bleeding. Its goal is not to fix the problem — that comes in eradication — but to prevent further damage while the team gathers information and prepares a thorough response. There are two types of containment:

Short-Term Containment (Immediate — within minutes)

- Network isolation: Disconnect the affected system from the network using firewall rules or by physically unplugging the network cable. This prevents lateral movement and data exfiltration. Do NOT power off the system — volatile evidence (active processes, memory, open connections) will be lost.
- Block suspicious ports at the firewall: Immediately block any external traffic on the confirmed attack vector. For example, if exploitation via port 1524 is confirmed, block all traffic to that port at the network perimeter immediately.
- Disable compromised accounts: If a user account has been confirmed as compromised, disable it immediately at the directory/authentication level. This does not affect the investigation.
- Preserve the current state: Take a memory dump and snapshot of the affected system before making any changes. Every action after this point must be logged with a timestamp.

Long-Term Containment (While eradication is prepared)

- Deploy a clean replacement system (if available) so business operations can continue while the compromised system is analysed
- Apply temporary firewall rules to block the attack vector across ALL systems in the environment — not just the confirmed victim. If vsftpd on port 21 was exploited on one system, block port 21 organisation-wide until patching is complete.
- Increase monitoring across all remaining systems — the confirmed incident may be a distraction while the attacker moves laterally to other targets
- Communicate to relevant staff that the affected system is offline — use the communication plan in Section 5

PHASE 4 | ERADICATION

Eradication removes the threat from the environment completely. This phase cannot begin until containment is confirmed — starting eradication on an active, spreading threat will not work. Eradication must be thorough: a partially removed attacker will simply re-establish access.

Eradication Steps

- Step 7. Identify and remove all malware, backdoors, and unauthorised software. For Metasploitable 2 vulnerabilities, this includes: disabling vsftpd (replace with SFTP), disabling UnrealIRCd service, removing the Ingreslock entry from /etc/inetd.conf, disabling distccd.
- Step 8. Close all backdoored and unnecessary open ports. Block ports at the firewall AND disable the underlying services at the OS level. Both are required — firewall rules can be changed; disabled services cannot run.
- Step 9. Audit all user accounts: identify any accounts created by the attacker, any accounts with modified permissions, and any accounts used during the incident. Disable and investigate all suspect accounts.
- Step 10. Rotate ALL credentials on the affected system and any system that shared credentials with it. This includes: OS user passwords, database passwords (MySQL root, PostgreSQL), service account passwords, SSH keys.
- Step 11. Patch all vulnerabilities that were exploited or could have been exploited during the incident window.

Apply in priority order: Critical first, then High. Use the Week 4 priority list as a guide.

Step 12. Scan the system with a vulnerability scanner after patching to confirm no residual exposures remain. Rescan 48 hours after eradication to catch any missed items.

Step 13. Check for persistence mechanisms: cron jobs, startup scripts, modified system binaries, scheduled tasks, or new services that could allow the attacker to regain access.

PHASE 5 | RECOVERY

Recovery restores systems to full operational status after the threat has been completely removed. Recovery must be deliberate and verified — returning a system to production before it is clean risks repeating the incident and losing the trust of the organisation.

Recovery Steps

Step 14. Verify the system is clean: the System Administrator confirms eradication is complete; a secondary reviewer (Data Custodian or external party) independently confirms. Both must sign off before recovery begins.

Step 15. Restore data from a verified clean backup. Confirm the backup pre-dates the incident by checking timestamps. If the backup may have been taken after the compromise began, go to the previous backup and treat the gap as data loss.

Step 16. Rebuild from known-good if necessary: for confirmed deep compromise (rootkit installed, OS-level changes), a full rebuild from a trusted base image is safer than attempting to clean the existing system.

Step 17. Reconnect to the network in a monitored state. Before full production restoration, run the system with enhanced logging and monitoring for a minimum of 48 hours to detect any signs of persistent access.

Step 18. Gradually restore services. Start with the least critical services and confirm stability before restoring critical operations. Do not restore all services at once.

Step 19. Notify stakeholders that systems are being restored. Provide a realistic timeline. Do not announce full recovery until the 48-hour monitored period is complete and clean.

Step 20. Document the recovery actions and the final system state in the Incident Log.

PHASE 6 | POST-INCIDENT REVIEW

The post-incident review transforms a bad experience into organisational learning. Every incident — even a Low-severity near miss — produces information that can improve detection, response, and prevention. This phase must be completed within 30 days for all Medium and above incidents, and within 7 days for Critical incidents.

Post-Incident Review Process

Step 21. Schedule the review meeting within 5 business days of incident closure. Attendees must include: ISO (chair), System Administrator, Data Custodian, and any personnel directly involved in the response.

Step 22. Prepare the Incident Timeline: a chronological record of every event from initial detection to full recovery, with timestamps. This is built from the Incident Log (Section 5).

Step 23. Conduct the review using the following questions as structure:

- What happened, and when? (Timeline)
- How was the incident detected? Was detection fast enough?
- Were the right people notified in time? Did the escalation path work?
- Were containment actions effective? Was anything missed?

- Was the eradication complete? Did the attacker attempt to re-establish access?
- Were backups available and usable? How long did recovery take?
- What could have prevented this incident from occurring at all?

Step 24. Produce the Post-Incident Report. This must contain: incident summary, timeline, root cause analysis, impact assessment (systems, data, operations, reputation), list of all actions taken, and recommendations.

Step 25. Update the Risk Register. If a new vulnerability was discovered during the incident, add it. If an existing vulnerability was exploited, mark it as confirmed and update its priority.

Step 26. Update security policies and this playbook. If the incident revealed a gap in any policy or procedure, update it within 30 days. If the playbook response procedures need adjusting, do so and re-communicate to all personnel.

Step 27. Assign remediation owners and deadlines for every recommendation. Track progress in the next governance meeting.

SECTION 5: COMMUNICATION & ESCALATION PLAN

5. Communication & Escalation Plan

Poor communication during an incident can be as damaging as the incident itself. Rumour, panic, or premature public disclosure can cause reputational damage, regulatory violations, and operational disruption. This section defines who communicates what, to whom, and when.

5.1 Internal Communication Rules

- All internal incident communications must go through the designated #security-incidents channel or emergency phone tree – no ad-hoc messaging on personal apps
- No member of staff may discuss incident details outside their confirmed need-to-know until the ISO provides clearance
- The Communications Officer drafts all internal updates; the ISO approves before distribution
- Staff updates must be factual, calm, and action-oriented: what happened (high level), what is being done, what staff should do (or not do)

5.2 Escalation Timeline

Time	Severity	Action	Who Is Notified
T+0	All	Incident detected and initial report made by first responder	System Administrator + immediate Line Manager
T+15 min	Critical	ISO declares Critical incident; containment begins; all-hands activated	ISO + System Administrator + Data Custodian + Board
T+30 min	Critical / High	Incident Scope confirmed; affected systems isolated; evidence preservation underway	ISO + full response team
T+1 hour	High	ISO declares High incident; Technical Lead leads response; initial staff communication issued	ISO + System Administrator + Board (High only)
T+2 hours	Critical / High	Data Custodian completes initial data impact assessment; ISO reviews for external notification requirement	ISO + Data Custodian + Legal (if data breach)
T+4 hours	Medium	System Administrator addresses Medium incident; initial containment actions complete	ISO (informed) + System Administrator
T+24 hours	All	Full incident report draft submitted to ISO; external notification sent if required (data breach: 72-hour regulatory clock)	ISO + Board + Regulators (if applicable)
T+30 days	Medium+	Post-incident review complete; updated policies circulated; risk register updated	Full governance team

5.3 External Communication Guidelines

- No external statement about the incident – to media, customers, partners, or regulators – is issued without the ISO's written approval
- If personal data of customers or partners may have been accessed, the ISO must consult with legal counsel before any external notification. Regulatory notification timelines (e.g., 72 hours for data breach under GDPR equivalents) must be respected.
- External communications must never speculate about causes, blame, or attacker identity until confirmed through investigation
- Social media monitoring should be activated during a Critical or High incident to detect if the incident becomes public before the organisation is ready to communicate

5.4 Incident Log

Every incident must be documented in real time using the Incident Log. The log is the legal and operational record of the response. It must never be altered after the fact – only appended.

Incident ID	Timestamp	Action Taken	Performed By	Result / Observation

SECTION 6: SPECIFIC INCIDENT RESPONSE PLAYBOOKS

6. Specific Incident Response Playbooks

This section contains targeted response procedures for the most critical incident types identified from the Metasploitable 2 vulnerability assessment. Each playbook follows the full lifecycle: Detect Contain Eradicate Recover. Use the Incident Type Classification (Section 2.2) to identify the correct playbook, then follow it step by step.

PLAYBOOK A | BACKDOOR / ROOT SHELL EXPLOITATION | SEVERITY: CRITICAL

Covers

vsftpd backdoor (CVE-2011-2523) | UnrealIRCd backdoor (CVE-2010-2075) | Ingreslock root shell (port 1524)

A1 – Detect

- Alert triggers: IDS fires on connection to port 1524, 6200 (vsftpd backdoor trigger), or 6667 (UnrealIRCd) from external IP
- Log indicator: Root login event in /var/log/auth.log with no preceding sudo or legitimate su command
- Process indicator: Unexpected shell process (sh, bash) with parent process of vsftpd, unrealircd, or inetd
- Network indicator: Outbound connection on unusual port from server to attacker C2 (command and control) IP
- User report: Employee notices system is unresponsive or behaving unusually; unknown files appear; CPU usage spikes

A2 – Classify & Notify

- Classify as CRITICAL – Backdoor/RCE type
- Phone the ISO immediately – do not use potentially compromised systems for communication
- ISO notifies Board within 15 minutes

A3 – Contain

- IMMEDIATELY isolate the affected system from the network – firewall rule or physical disconnection. Do NOT power off.
- Block ports 1524, 6200, 6667, 21 at the network perimeter for ALL systems
- Take a memory dump: 'sudo dd if=/dev/mem of=/forensics/memdump.img' (adjust path)
- Capture network state: 'netstat -an > /forensics/netstat_\$(date +%s).txt'
- Disable all non-essential accounts immediately

A4 – Eradicate

- Kill the active backdoor session: identify PID ('ps aux | grep -E "sh|bash" | grep -v grep') then kill -9 [PID]
- Remove Ingreslock from /etc/inetd.conf: 'grep -v ingreslock /etc/inetd.conf > /tmp/inetd_clean.conf && mv /tmp/inetd_clean.conf /etc/inetd.conf'
- Stop and disable vsftpd: 'service vsftpd stop && update-rc.d vsftpd disable'
- Stop and disable UnrealIRCd: 'service unrealircd stop && update-rc.d unrealircd disable'

- Audit /etc/passwd, /etc/shadow for attacker-created accounts (look for new entries with UID 0 or unusual home directories)
- Rotate all system credentials — root password, all user passwords, SSH keys
- Apply available patches for CVE-2011-2523 and CVE-2010-2075 (upgrade to non-backdoored versions or replace with secure alternatives)

A5 — Recover

- Rebuild system from a clean baseline image if root-level compromise is confirmed
- Restore data from the most recent pre-incident clean backup
- Reconnect in monitored state; monitor for 48 hours before returning to production
- Run a full vulnerability scan post-recovery to confirm no residual exposures

PLAYBOOK B | CREDENTIAL THEFT & UNAUTHORISED REMOTE ACCESS | SEVERITY: HIGH

Covers

Telnet plaintext credential harvest (CVE-2022-39028) | VNC authentication bypass (CVE-2006-2369) | MySQL brute force (CVE-2008-0226)

B1 — Detect

- Telnet traffic detected on port 23 (any Telnet traffic is suspicious — the service should be disabled)
- VNC connection logged on port 5900 from an IP not on the approved access list
- MySQL remote connection attempt on port 3306 from external IP (should be localhost-only)
- Multiple failed logins on any service followed by a successful login from the same IP (brute force pattern)
- Credentials appearing in use on a system at an unusual time or from an unusual location

B2 — Contain

- Disable Telnet service immediately: 'service telnetd stop'
- Block port 5900 at the firewall — VNC must not be accessible without SSH tunnel
- Restrict MySQL to localhost: edit /etc/mysql/my.cnf — change 'bind-address = 0.0.0.0' to 'bind-address = 127.0.0.1' and restart MySQL
- Disable all accounts where credentials may have been intercepted. Issue forced password reset for ALL accounts once system is secured.

B3 — Eradicate

- Remove telnetd: 'apt-get remove telnetd' (replace with SSH)
- Upgrade VNC to a version with authentication; configure VNC to accept connections via SSH tunnel only
- Rotate all MySQL database credentials; disable MySQL remote root login ('DELETE FROM mysql.user WHERE User='root' AND Host!='localhost'; FLUSH PRIVILEGES;')
- Review all access logs for the window during which credentials may have been exposed; identify any actions taken using stolen credentials

B4 — Recover

- Verify no data was exfiltrated during the period of unauthorised access (review MySQL query logs, VNC

session logs)

- Restore any modified data from backup
- Issue mandatory MFA enrollment for all affected accounts before re-enabling access

PLAYBOOK C | DATA EXFILTRATION & NFS UNAUTHORISED ACCESS | SEVERITY: HIGH / CRITICAL

Covers

NFS unauthorised file access (CVE-2006-3005) | MySQL data dump (CVE-2008-0226) | Any confirmed data exfiltration event

C1 — Detect

- Unusual outbound data transfer volume from the server (baseline deviation in network monitoring)
- NFS mount activity from an IP not in the authorised hosts list (/etc/exports)
- mysqldump process running outside of scheduled backup windows
- Large file read activity on NFS-shared directories detected in system logs

C2 — Contain

- Block NFS traffic at the firewall (port 2049) immediately for all but pre-approved IPs
- Stop the NFS service: 'service nfs-kernel-server stop'
- Terminate any active mysqldump or suspicious MySQL sessions: 'SHOW PROCESSLIST; KILL [ID];'
- Block all outbound traffic from the affected system except for essential monitoring connections

C3 — Eradicate

- Review and restrict /etc/exports — allow only trusted IP ranges, use 'ro' (read-only) where write access is not needed, add 'root_squash' option
- Upgrade NFS to NFSv4 with Kerberos authentication; consider VPN requirement for NFS access
- Restrict MySQL to localhost; implement database activity monitoring
- Assess what data was exfiltrated: review NFS access logs and MySQL query logs for the incident window. Document and report to ISO.

C4 — Recover

- If customer or employee personal data was exfiltrated: initiate legal and regulatory notification process immediately
- Restore data integrity from backup if any data was modified
- Implement Data Loss Prevention (DLP) monitoring for future detection

SECTION 7: INCIDENT RESPONSE WORKFLOW DIAGRAM

7. Incident Response Workflow Diagram

The diagram below provides a visual representation of the full incident response process, from initial detection through to post-incident review. Each decision point and action is mapped to the responsible role and the corresponding phase of the NIST lifecycle.



Note: For Critical and High incidents, Phases 3 (Contain) and 4 (Eradicate) may begin before Phase 2 (Identification) is fully complete. Speed of containment is prioritised over completeness of analysis in active incidents. Documentation catches up – but it must catch up.

SECTION 8: APPENDIX – QUICK REFERENCE & DOCUMENT CONTROL

8. Quick Reference Card

Print this page and keep it at every workstation. If an incident occurs, this card tells you what to do in the first five minutes.

IF YOU NOTICE SOMETHING SUSPICIOUS:	CONTACT LIST:
1. STOP – do not touch the affected system 2. RECORD – write down what you saw and when 3. REPORT – call the ISO or System Administrator NOW 4. WAIT – do not investigate, fix, or tell others until instructed 5. FOLLOW – comply with all instructions from the Incident Commander	ISO (Incident Commander): [Insert Name & Number] System Administrator: [Insert Name & Number] Data Custodian: [Insert Name & Number] Security Incident Channel: #security-incidents (Slack) Emergency Email: security@organisation.com

8.1 Incident Response Checklist – Critical/High Incidents

Detection & Identification	Eradication
Incident detected and reported immediately	Backdoors removed and services disabled
Incident ID assigned	Credentials rotated on all affected systems
Logs captured and preserved	Vulnerabilities patched (Critical within 24 hrs)
Scope determined	Persistence mechanisms checked and removed
Severity classified (Critical/High/Medium/Low)	Full vulnerability scan post-eradication
ISO notified within correct time window	Recovery
Board notified (Critical/High)	System verified clean by 2 independent parties
Containment	Data restored from pre-incident backup
Affected system isolated from network	Monitored reconnection (min. 48 hours)
Memory dump and evidence preserved	Gradual service restoration confirmed stable
Compromised accounts disabled	Post-Incident
Temporary firewall rules applied	Post-incident review scheduled
Incident Log opened and active	Root cause identified
Communications Officer briefed	Risk register updated

9. Document Control

Version	Date	Author	Changes
v1.0	May 2026	Group 8 – Thrive Africa	Initial release – full playbook, classification

			system, workflow diagram, and specific playbooks
--	--	--	--

10. Glossary

Term	Definition
NIST SP 800-61	National Institute of Standards and Technology – Computer Security Incident Handling Guide. The framework this playbook is based on.
Incident Commander	The person with overall authority and accountability during an incident response. In this organisation, this is the Information Security Officer (ISO).
IoC (Indicator of Compromise)	A piece of forensic data that suggests a system has been breached. Examples: unusual process, unexpected outbound connection, modified system file.
RCE (Remote Code Execution)	A class of vulnerability that allows an attacker to run arbitrary commands on a target system from a remote location.
Lateral Movement	After gaining access to one system, an attacker moves through the network to access other systems, often gaining escalating privileges.
C2 (Command & Control)	The server or channel an attacker uses to control compromised systems after initial exploitation.
Containment	Actions taken to limit the spread and damage of an incident while the response continues. Does not remove the threat – that is eradication.
Eradication	Complete removal of the attacker's presence, tools, backdoors, and any modified files from the environment.
CVE	Common Vulnerabilities and Exposures – a unique identifier for publicly known security vulnerabilities.
CVSS	Common Vulnerability Scoring System – a score (0–10) indicating the severity of a vulnerability.

— End of Incident Response Playbook —

Group 8 | Thrive Africa Cybersecurity Internship | Week 6 | May 2026